Lección 01 — Introducción a Linux y Kali 2026

Módulo 01: Fundamentos de Linux · Pruebas de penetración con Kali Linux

Linux es el entorno operativo de cada prueba de penetración seria. Kali no es la única distribución que vas a encontrar: aterrizarás en servidores Ubuntu, contenedores Alpine, dispositivos BusyBox incrustados y bastiones Debian endurecidos. El modelo mental es siempre el mismo: un kernel compartido, un árbol de sistema de archivos unificado, un pequeño conjunto de límites de confianza expresados como permisos y capacidades de archivos, y una caja de herramientas de programas pequeños y componibles unidos por un shell.

Entender cómo está organizado el sistema no es académico. Te dice dónde se filtran credenciales (`/etc/shadow`, `~/.ssh/`, `/var/log/auth.log`), dónde viven las tareas programadas (`/etc/cron.*`, temporizadores de systemd), dónde se esconden los binarios SUID de propiedad de root y dónde un atacante suele dejar sus herramientas. El resto del módulo recorre las piezas de Linux que un pentester toca en cada compromiso: sistema de archivos, usuarios y grupos, procesos, el shell, procesamiento de texto, red desde la línea de comandos, administración de paquetes, servicios, controles de seguridad y scripts. Al final deberías poder mirar una máquina nueva y saber en minutos dónde están los archivos interesantes, quién los posee y cómo llegar a ellos.

Introducción

Cada pentester necesita un arma, y esa arma ejecuta Linux. No porque esté de moda, sino porque Linux da control completo sobre la máquina, la pila de red y las herramientas de maneras que ningún otro sistema permite. Antes de ejecutar tu primer escaneo con Nmap o crear tu primera carga útil, tienes que entender el terreno en el que te encuentras.

Esta lección te lleva de cero a una plataforma de ataque Kali Linux 2026 totalmente operativa. En el camino entenderás por qué Linux se volvió el sistema operativo dominante en ciberseguridad, qué hace distinto a Kali y cómo configurar tu entorno para que sirva durante meses de aprendizaje y compromisos reales.

1. Historia y filosofía de Linux

1.1 De Unix a Linux

La historia empieza en 1969 en Bell Labs, donde Ken Thompson y Dennis Ritchie construyeron Unix, un sistema diseñado en torno a dos ideas radicales: *todo es un archivo* y *los programas pequeños que hacen una cosa bien se pueden componer entre sí*. Estas ideas son la base de la filosofía Unix y siguen siendo la razón por la que Linux es tan poderoso para el trabajo de seguridad.

Unix era propietario. Las universidades podían usarlo, pero el uso comercial requería licencias caras. En 1983, Richard Stallman lanzó el Proyecto GNU para construir un sistema libre compatible con Unix. GNU aportó las herramientas de espacio de usuario (compiladores, editores, shells, utilidades), pero le faltaba un kernel.

En 1991, un estudiante finlandés de informática, Linus Torvalds, escribió ese núcleo. Lo publicó en un grupo de noticias de Usenet con la ahora famosa subestimación: “Estoy haciendo un sistema operativo (gratuito) (solo un pasatiempo, no será grande y profesional como GNU)”. Ese núcleo, combinado con las herramientas de GNU, dio origen a GNU/Linux, comúnmente llamado simplemente “Linux”.

Referencias: Proyecto GNU — historia · kernel.org

1.2 Por qué Linux domina la seguridad

- **El código abierto es auditable.** Cuando tu trabajo es encontrar vulnerabilidades, necesitas herramientas que puedas inspeccionar, modificar y en las que puedas confiar. Las herramientas de código cerrado son cajas negras. Las de código abierto te permiten leer cada línea.
- **La composición permite la automatización.** La filosofía Unix de conectar pequeñas herramientas permite crear flujos complejos a partir de componentes simples. Un pentester que domina tuberías, redirecciones y procesamiento de texto puede automatizar en minutos lo que tomaría horas en una interfaz gráfica.
- **El acceso a nivel de sistema es nativo.** Linux ofrece sockets en bruto, carga de módulos del kernel, manipulación de la pila de red e inyección de procesos mediante interfaces estándar. En Windows muchas de estas cosas requieren controladores especiales o escalar privilegios. En Linux forman parte del diseño.
- **Los servidores ejecutan Linux.** La gran mayoría de los servidores web del mundo corren Linux. Los sistemas que encontrarás al probar una organización (servidores web, bases de datos, hosts de contenedores, instancias en la nube) son, en su mayoría, Linux. Conocer a fondo el sistema operativo objetivo es fundamental.

> **Perspectiva:** la mayor ventaja que Linux te da como pentester no son las herramientas, sino la mentalidad. Linux te obliga a entender lo que sucede en cada nivel. No hay un asistente “Siguiente → Siguiente → Finalizar” que oculte los detalles. Cada decisión de configuración es explícita, y esa explicitud construye el modelo mental que necesitas para encontrar vulnerabilidades.

1.3 El ecosistema de código abierto

Linux no es una sola cosa: es un núcleo rodeado de un vasto ecosistema. El kernel maneja la abstracción del hardware, la administración de memoria, la planificación de procesos y las llamadas al sistema. Todo lo que está por encima del kernel (el shell, el gestor de paquetes, el entorno de escritorio, las herramientas) proviene de proyectos independientes.

Esta modularidad permite que distintos grupos combinen los componentes de formas diferentes. Estas combinaciones se llaman **distribuciones** (distros).

2. Distribuciones Linux: entendiendo el panorama

2.1 Familias de distribuciones

Familia Debian (paquetes `.deb`, gestor `apt`):

- **Debian**: la roca de la estabilidad, con paquetes conservadores y bien probados. Los servidores la prefieren.
- **Ubuntu**: derivado de Debian fácil de usar, con una comunidad enorme y lanzamientos frecuentes.
- **Kali Linux**: basado en Debian, construido específicamente para pruebas de penetración y auditoría de seguridad.
- **Parrot OS**: otro derivado de Debian centrado en seguridad, más liviano que Kali.

Familia Red Hat (paquetes `.rpm`, gestor `dnf` / `yum`):

- **Fedora**: vanguardia; sirve de campo de pruebas para Red Hat Enterprise Linux.
- **CentOS Stream / Rocky Linux / AlmaLinux**: distribuciones empresariales para servidores.
- **Red Hat Enterprise Linux (RHEL)**: estándar empresarial comercial.

Familia Arch (lanzamiento continuo, gestor `pacman`):

- **Arch Linux**: minimalista, lanzamiento continuo; enseña todo haciéndolo a mano.
- **BlackArch**: distribución de seguridad basada en Arch con más de 2800 herramientas.
- **Manjaro**: derivado de Arch fácil de usar.

Independientes:

- **Gentoo**: basado en código fuente; compila todo. Control profundo, curva de aprendizaje pronunciada.
- **Alpine**: minimalista, basado en musl, muy usado en contenedores Docker.
- **NixOS**: configuración declarativa y compilaciones reproducibles.

Referencias: Debian · Kali Linux — documentación · Arch Linux

2.2 ¿Por qué Kali Linux para pruebas de penetración?

Kali existe porque Offensive Security (hoy OffSec) notó que los pentesters perdían tiempo ensamblando y manteniendo colecciones de herramientas. Kali resuelve eso con:

- **Arsenal preinstalado.** Más de 600 herramientas organizadas por categoría: recopilación de información, análisis de vulnerabilidades, ataques a aplicaciones web, ataques a contraseñas, redes inalámbricas, explotación, análisis forense y más. No son repositorios aleatorios de GitHub: se seleccionan, prueban y mantienen.
- **Lanzamiento continuo (rolling).** A diferencia de las distribuciones de versión fija que se actualizan cada seis meses, Kali sigue a Debian Testing de forma continua. Siempre tienes versiones recientes de las herramientas.
- **Parches de kernel para trabajo de seguridad.** Incluye soporte para inyección inalámbrica (crítico para pruebas WiFi), dispositivos de ataque USB y configuraciones optimizadas para herramientas de seguridad.
- **Modo forense.** Puede arrancar sin montar discos automáticamente y sin habilitar la swap. Es esencial cuando se maneja evidencia en respuesta a incidentes, porque no debes alterar el sistema analizado.
- **Soporte ARM y contenedores.** Funciona en Raspberry Pi, en Android (mediante NetHunter) y en Docker, lo que permite llevar una plataforma de pentest en el bolsillo.

> **Perspectiva:** Kali es una herramienta, no un estilo de vida. Es un error común instalarlo como computadora diaria para navegar, leer correo y trabajar. Hay varias razones para evitarlo: el ecosistema asume privilegios elevados, muchas herramientas de seguridad tienen comportamientos de red agresivos, y usar una distribución de seguridad para tareas personales expone tus datos a herramientas diseñadas para ser invasivas. Usa Kali en una máquina virtual o en un equipo dedicado, y mantén separada tu computación personal.

3. Kali Linux 2026: qué hay de nuevo

3.1 Kernel y base del sistema

Kali 2026 viene con la serie 6.x del kernel de Linux, que ofrece mejor soporte de hardware, mejores capacidades de eBPF para monitoreo de red y mejoras de seguridad como el sandboxing de io_uring.

El sistema base usa Python 3.12 o superior por defecto, lo que mejora el rendimiento y trae nuevas características de lenguaje a todo el ecosistema de herramientas. Las herramientas

que requerían Python 2 se migraron o eliminaron.

3.2 Usuario por defecto

Un cambio importante para quienes empiezan: Kali ya no ejecuta todo como root. Las versiones anteriores lo hacían porque muchas herramientas necesitan privilegios elevados. El enfoque actual usa un usuario estándar (`kali`) con acceso a `sudo`:

```
# El usuario por defecto en Kali 2026
$ whoami
kali

# Elevar privilegios cuando se necesiten
$ sudo nmap -sS -sV 10.10.10.1

# Obtener una shell de root cuando se necesite acceso sostenido
$ sudo -i
```

Este cambio sigue las buenas prácticas: operar como root por defecto es cómodo pero peligroso, sobre todo al conectarse a redes hostiles durante un compromiso.

3.3 Herramientas nuevas y actualizadas

Cada versión de Kali agrega herramientas. Algunas adiciones recientes:

- **Ligolo-ng**: herramienta moderna de túneles y pivoteo, que reemplaza flujos más antiguos basados en SSH. Referencia: github.com/nicocha30/ligolo-ng
- **Certipy**: explotación de servicios de certificados de Active Directory.
- **Nuclei**: escáner de vulnerabilidades rápido basado en plantillas. Referencia: projectdiscovery.io
- **httpx**: kit de herramientas HTTP rápido para sondeo.
- **Katana**: rastreador web de nueva generación de ProjectDiscovery.
- **NetExec**: sucesor de CrackMapExec, mantenido activamente. Referencia: github.com/Pennyw0rth/NetExec
- **Sliver**: framework C2 de código abierto, alternativa a Cobalt Strike.
- **Caido**: herramienta moderna de pruebas de seguridad web, alternativa a Burp Suite. Referencia: caido.io

3.4 Integración con contenedores

Kali 2026 tiene soporte de primera clase para Docker:

```
# Instalar Docker en Kali
sudo apt install -y docker.io docker-compose-v2
sudo systemctl enable docker --now
sudo usermod -aG docker $USER
```

```
# Descargar un contenedor de Kali para uso aislado de herramientas
docker pull kalilinux/kali-rolling
docker run -it kalilinux/kali-rolling /bin/bash
```

Esto importa porque muchos laboratorios de pentest (DVWA, JuiceShop, crAPI) corren como contenedores Docker, y usarás Docker a lo largo del curso. Referencia: documentación de Docker

4. Métodos de instalación

Hay varias formas de ejecutar Kali. Cada una tiene sus compromisos. Elige según tu hardware, tu caso de uso y tu comodidad.

4.1 Máquina virtual (recomendado para principiantes)

Una máquina virtual es el punto de partida más seguro y flexible. Ofrece instantáneas (puntos de restauración), aislamiento de red y la posibilidad de ejecutar Kali junto con el sistema anfitrión.

VMware Workstation / Player

VMware ofrece mejor rendimiento que VirtualBox para trabajo de seguridad, sobre todo para virtualización anidada y paso de dispositivos USB:

```
# Descargar la imagen VMware precompilada desde kali.org/get-kali/
# Extraer el archivo 7z
7z x kali-linux-2026-vmware-amd64.7z

# Abrir el archivo .vmx en VMware
# Antes del primer arranque, ajustar la configuración
```

Configuración recomendada de VMware para trabajo de pentest:

Configuración	Valor recomendado	Por qué
RAM	4 GB mínimo, 8 GB ideal	Herramientas como Burp Suite y los navegadores consumen memoria
CPUs	2 a 4 núcleos	El escaneo en paralelo y el cracking se benefician de los núcleos
Disco	80 GB o más (dinámico)	Bases de datos de herramientas, listas de

Configuración	Valor recomendado	Por qué
		palabras y capturas crecen rápido
Red	NAT + Host-Only	NAT para internet, solo anfitrión para la comunicación del laboratorio
USB	Controlador USB 3.0	Adaptadores WiFi y dispositivos HID necesitan paso USB
Pantalla	Aceleración 3D activada	Experiencia de escritorio más fluida

> **Perspectiva:** crea siempre una instantánea limpia inmediatamente después de la configuración y las actualizaciones. Antes de cada ejercicio o compromiso, crea otra. Así tienes una reversión instantánea cuando una herramienta se comporta mal, cuando modificas archivos del sistema por accidente o cuando necesitas un entorno nuevo. Los pentesters profesionales mantienen máquinas virtuales separadas por cliente para evitar la contaminación cruzada.

VirtualBox

Gratuito y multiplataforma, VirtualBox es la alternativa universal:

```
        # Descargar la imagen OVA precompilada desde kali.org
        # Importar: File → Import Appliance → seleccionar el archivo .ova

        # Modos de red de VirtualBox que debes entender:
        # NAT         — la VM obtiene internet a través del anfitrión, aislada de la red del anfitrión
        # Bridged     — la VM aparece como un dispositivo en tu red física
        # Host-Only   — la VM solo puede hablar con el anfitrión (y con otras VM Host-Only)
        # Internal    — las VM solo se comunican entre sí (sin anfitrión, sin internet)
```

Entender los modos de red no es solo cuestión de instalación: es comprender la segmentación de red, un concepto central en pruebas de penetración:

- **NAT** es el valor predeterminado para acceso seguro a internet.
- **Host-Only** es la forma de crear redes de laboratorio aisladas.
- **Internal** es la forma de simular redes corporativas segmentadas con varias máquinas objetivo.
- **Bridged** casi nunca se usa para pentesting, porque expone la VM a tu red real.

Configuración de red para laboratorios

Una configuración práctica usa dos adaptadores:

- **Adaptador 1: NAT** (acceso a internet para actualizaciones y descargas de herramientas).
- **Adaptador 2: Host-Only** (comunicación con las máquinas objetivo).

Esto refleja un compromiso real: tu máquina de ataque tiene acceso a internet, pero también está conectada a una red objetivo aislada.

Referencia: manual de VirtualBox

4.2 WSL2 en Windows

El Subsistema de Windows para Linux 2 ofrece un kernel real de Linux que corre dentro de Windows, con buen rendimiento:

```
        # Habilitar WSL2 (ejecutar PowerShell como administrador)
        wsl --install -d kali-linux

        # Después de la instalación y reinicio:
        wsl -d kali-linux

        # Instalar la experiencia de escritorio de Kali (Win-KeX)
        sudo apt update && sudo apt install -y kali-win-kex

        # Modos gráficos:
        kex --win     # modo en ventana (ventana separada)
        kex --esm     # Enhanced Session Mode (basado en RDP, mejor integración)
        kex --sl      # modo seamless (las apps de Linux aparecen como ventanas de
Windows)
```

Limitaciones de WSL2 para pentesting:

- **Sin acceso a sockets en bruto por defecto.** Herramientas como los escaneos SYN de Nmap (`-sS`) requieren soluciones alternativas.
- **Sin paso de USB.** Los adaptadores WiFi para pruebas inalámbricas no funcionan.
- **Diferencias en la pila de red.** WSL2 usa un conmutador virtual, y algunas herramientas de enumeración se comportan distinto.
- **Sin carga de módulos del kernel.** Los módulos personalizados para pruebas especializadas no son posibles.

WSL2 es excelente para pruebas de aplicaciones web, scripting y desarrollo de herramientas. Para pruebas a nivel de red y ataques inalámbricos necesitas una máquina virtual completa o hardware dedicado. Referencia: documentación de WSL

4.3 Instalación en hardware dedicado (bare metal)

Para hardware de pentest dedicado (un portátil usado exclusivamente para compromisos):

```
        # Arrancar desde USB (creado con Rufus, Etcher o dd):
        sudo dd if=kali-linux-2026-installer-amd64.iso of=/dev/sdX bs=4M status=progress

        # Durante la instalación:
        # 1. Elegir "Graphical Install"
        # 2. Definir un hostname (no uses "kali": es identificable en las redes)
        # 3. Disco completo con LVM cifrado (SIEMPRE cifrar en equipos de compromiso)
        # 4. Elegir el entorno de escritorio (Xfce es el predeterminado: liviano y
confiable)
        # 5. Seleccionar software: el meta-paquete "large" para el conjunto completo de
herramientas
```

Por qué importa el cifrado en el hardware de compromiso: cuando haces una prueba de penetración, tu equipo contiene datos del cliente: mapas de red, credenciales, detalles de vulnerabilidades, capturas de pantalla. Si el portátil se pierde o lo roban, esos datos deben estar protegidos. El cifrado completo del disco con una frase de contraseña robusta no es opcional en el trabajo profesional: es un requisito legal y ético.

> **Advertencia de seguridad:** si realizas pruebas de penetración autorizadas de forma profesional, tu hardware de compromiso DEBE usar cifrado completo de disco. Muchos marcos de cumplimiento (PCI DSS, ISO 27001) y contratos con clientes lo exigen. Un portátil sin cifrar que es robado es un incidente, para tu cliente y para ti.

4.4 Instancias en la nube

Para pruebas remotas o cuando necesitas una dirección IP limpia:

```
        # AWS (elegible para el nivel gratuito: t2.micro, pero con poca potencia)
        # Mejor: t3.medium (2 vCPU, 4 GB de RAM)
        # Buscar "Kali Linux" en AWS Marketplace: existe una imagen oficial de OffSec

        # DigitalOcean (más simple, unos 24 USD al mes para especificaciones útiles)
        doctl compute droplet create kali-pentest \
          --image kali-linux \
          --size s-2vcpu-4gb \
          --region nyc1 \
          --ssh-keys $(doctl compute ssh-key list --format ID --no-header)

        # Google Cloud
        gcloud compute instances create kali-pentest \
          --zone=us-central1-a \
          --machine-type=e2-medium \
          --image-project=kali-linux-cloud \
          --image-family=kali-rolling
```

Las instancias en la nube sirven para:

- Pruebas desde distintas ubicaciones geográficas.

- Escaneos largos sin depender de tu portátil.
- Mantener una reputación de IP limpia, usando instancias desechables.
- Colaboración: varios pentesters accediendo a la misma máquina.

4.5 Contenedor Docker

Para aislar herramientas o integrar con CI/CD:

```
        # Contenedor básico de Kali
        docker run -it --name kali kalilinux/kali-rolling /bin/bash

        # Dentro del contenedor, instala lo que necesites
        apt update && apt install -y kali-tools-top10

        # Contenedor listo para pentest, con almacenamiento persistente
        docker run -it \
          --name kali-pentest \
          --hostname kali \
          -v ~/kali-data:/data \
          --cap-add=NET_RAW \
          --cap-add=NET_ADMIN \
          kalilinux/kali-rolling /bin/bash
```

Las opciones `--cap-add` son importantes: dan al contenedor las capacidades de Linux necesarias para operaciones de sockets en bruto (escaneo de puertos, construcción de paquetes) y administración de red (configuración de interfaces, operaciones ARP), sin ejecutar el contenedor completo como privilegiado.

4.6 Raspberry Pi y ARM

Kali es compatible con plataformas ARM, lo que permite construir dispositivos discretos:

```
        # Descargar la imagen ARM adecuada desde kali.org
        # Para Raspberry Pi 4/5:
        # kali-linux-2026-raspberry-pi-arm64.img.xz

        # Escribir en la tarjeta SD:
        xzcat kali-linux-2026-raspberry-pi-arm64.img.xz | sudo dd of=/dev/sdX bs=4M
status=progress
```

Una Raspberry Pi con Kali sirve para:

- **Cajas desplegables:** dejarla en la red de un cliente durante compromisos de acceso persistente.
- **Pruebas WiFi:** pequeña, portátil y con soporte para antena externa.
- **Pruebas de seguridad física:** disfrazada de un dispositivo IoT inofensivo.
- **Laboratorio portátil:** practicar en cualquier lugar.

5. Primera configuración

Después de instalar, configura el sistema correctamente. Estos no son pasos opcionales: saltarlos causa problemas durante los compromisos.

5.1 Actualizar el sistema

Actualiza siempre antes de cualquier otra cosa:

```
        # Actualización completa del sistema
        sudo apt update && sudo apt full-upgrade -y

        # Limpieza
        sudo apt autoremove -y && sudo apt autoclean
```

`apt update` actualiza el índice de paquetes (lo que está disponible). `apt full-upgrade` instala las actualizaciones y resuelve los cambios de dependencias, a diferencia de `apt upgrade`, que no elimina paquetes. En Kali, `full-upgrade` es la opción preferida.

5.2 Zona horaria y configuración regional

La zona horaria correcta es importante para correlacionar registros durante los compromisos:

```
        # Configurar la zona horaria
        sudo timedatectl set-timezone America/New_York  # ajustar a tu ubicación

        # Verificar
        timedatectl
        # Muestra: hora local, hora universal, hora del RTC, zona horaria, estado de
sincronización NTP

        # Configuración regional (normalmente correcta por defecto)
        sudo dpkg-reconfigure locales
```

> **Perspectiva para pentesters:** durante los compromisos, las marcas de tiempo de tus capturas, registros e informes deben coincidir con la zona horaria del cliente, o usar UTC de forma consistente. Las marcas de tiempo desalineadas generan confusión en la línea de tiempo de un incidente y pueden restar credibilidad a tus hallazgos.

Referencia: timedatectl (man page)

5.3 Configuración de usuario

```
# El usuario por defecto es 'kali' con acceso a sudo
# Cambia la contraseña por defecto de inmediato:
passwd

# Verificar acceso a sudo:
sudo -l
# Debe mostrar: (ALL : ALL) ALL

# Si necesitas crear usuarios adicionales (para laboratorios de varias personas):
sudo adduser analyst
sudo usermod -aG sudo analyst
```

5.4 Generación de claves SSH

Las claves SSH son más seguras que las contraseñas y son esenciales para conectarte a objetivos remotos y a tus instancias en la nube:

```
# Generar una clave Ed25519 (moderna, rápida y segura)
ssh-keygen -t ed25519 -C "pentest@kali-2026"

# Al preguntar:
# Archivo: aceptar el predeterminado (~/.ssh/id_ed25519)
# Frase de contraseña: DEFINIR UNA. Protege la clave si tu equipo se compromete.

# Ver tu clave pública (es la que compartes):
cat ~/.ssh/id_ed25519.pub

# Permisos correctos (SSH es estricto con esto):
chmod 700 ~/.ssh
chmod 600 ~/.ssh/id_ed25519
chmod 644 ~/.ssh/id_ed25519.pub
```

¿Por qué Ed25519 y no RSA? Las claves Ed25519 son más cortas (256 bits, frente a 3072 o más bits para una seguridad RSA equivalente), más rápidas de generar y verificar, y resisten varias clases de ataques de implementación que afectan a RSA. Para claves nuevas en 2026 no hay razón para usar RSA, salvo que necesites compatibilidad con sistemas antiguos.

Referencia: documentación de OpenSSH

5.5 Instalación de meta-paquetes

Kali organiza las herramientas en **meta-paquetes**: grupos de herramientas relacionadas que puedes instalar juntas:

```
# El conjunto esencial de las top 10 (instalación mínima)
sudo apt install -y kali-tools-top10

# Pruebas de aplicaciones web
sudo apt install -y kali-tools-web
```

```
        # Pruebas inalámbricas
        sudo apt install -y kali-tools-wireless

        # Recopilación de información
        sudo apt install -y kali-tools-information-gathering

        # Análisis de vulnerabilidades
        sudo apt install -y kali-tools-vulnerability

        # Herramientas de explotación
        sudo apt install -y kali-tools-exploitation

        # Ataques a contraseñas
        sudo apt install -y kali-tools-passwords

        # Ver todos los meta-paquetes disponibles:
        apt-cache search ^kali-tools-
```

Si instalaste Kali con la opción “large”, la mayoría ya está presente. En una instalación mínima o en un contenedor Docker, instala solo lo que necesites. Referencia: listado de herr amientas de Kali

5.6 Configuración de la terminal

Tu terminal es donde pasas la mayor parte del tiempo. Vale la pena hacerla eficiente:

```
        # Kali 2026 usa Zsh por defecto con un tema personalizado
        # Si quieres mejorarla:

        # Oh My Zsh (framework para configurar Zsh)
        sh -c "$(curl -fsSL
https://raw.githubusercontent.com/ohmyzsh/ohmyzsh/master/tools/install.sh)"

        # Plugins útiles de Zsh.
        # Edita ~/.zshrc y agrega a plugins=():
        plugins=(
          git                    # alias y estado de git en el prompt
          sudo                   # doble Esc antepone sudo
          command-not-found      # sugiere paquetes para comandos desconocidos
          zsh-autosuggestions    # sugerencias estilo fish a partir del historial
          zsh-syntax-highlighting # resaltado de sintaxis en tiempo real
        )

        # Instalar los plugins adicionales:
        git clone https://github.com/zsh-users/zsh-autosuggestions ${ZSH_CUSTOM:-~/.oh-
my-zsh/custom}/plugins/zsh-autosuggestions
        git clone https://github.com/zsh-users/zsh-syntax-highlighting ${ZSH_CUSTOM:-
~/.oh-my-zsh/custom}/plugins/zsh-syntax-highlighting

        # Aplicar cambios:
        source ~/.zshrc
```

El plugin `sudo` merece una mención especial: al presionar Esc dos veces, antepone `sudo` al comando actual. Cuando ejecutas comandos rápidos durante un compromiso y se te olvida elevar privilegios, esto ahorra segundos que se acumulan en minutos a lo largo de un día de pruebas. Usa esta función con cuidado: revisa el comando antes de ejecutarlo como root.

Referencias: Oh My Zsh · zsh-autosuggestions · zsh-syntax-highlighting

6. Primeros pasos esenciales: lo que los principiantes suelen olvidar

6.1 Kali no es una computadora de uso diario

Este punto es lo bastante crítico como para repetirlo con detalle. Usar Kali para la computación diaria crea problemas:

- **Las herramientas de seguridad escanean redes.** Si una herramienta inicia un servicio o envía sondas, tu ISP o el administrador de la red puede notarlo. Algunas herramientas se enlazan a puertos o responden a solicitudes de red de forma inesperada.
- **Las herramientas de ataque tienen superficie de ataque.** Metasploit abre una conexión a base de datos. Burp Suite ejecuta un proxy. Si estos servicios quedan expuestos, pueden volverse contra ti.
- **Las actualizaciones pueden romper cosas.** Los lanzamientos continuos priorizan las versiones más recientes sobre la estabilidad. Una actualización que cambia una biblioteca de Python puede romper las herramientas de navegación que usas a diario.
- **Contaminación forense.** Si tu Kali también es tu equipo personal, tus datos personales se mezclan con los del compromiso. Eso viola la confianza del cliente y puede contravenir requisitos legales.

El enfoque profesional: usa Kali en una máquina virtual que enciendes para trabajar y apagas al terminar. El sistema anfitrión se encarga de las tareas personales.

6.2 Estrategia de instantáneas

Las instantáneas son tu botón de deshacer:

```
# VMware: VM → Snapshot → Take Snapshot
# VirtualBox: Machine → Take Snapshot

# Crea estas instantáneas:
# 1. "Clean Install": justo después de la instalación y la primera actualización
# 2. "Pre-Engagement": antes de empezar cualquier trabajo para un cliente
# 3. "Pre-Exploit": antes de ejecutar acciones potencialmente destructivas en laboratorios
```

Una práctica disciplinada de instantáneas ahorra horas de reinstalación y evita la contaminación cruzada entre compromisos.

6.3 Aislamiento de la red

Al practicar técnicas ofensivas, no debes atacar sistemas reales por accidente:

```
# Verifica la configuración de red antes de cualquier prueba:
ip addr show

# Deberías ver:
# eth0 (o ens33): tu adaptador NAT, acceso a internet
# eth1 (o ens34): tu adaptador Host-Only, solo red del laboratorio

# Si ves un adaptador bridged conectado a tu red doméstica u oficina:
# DETENTE y reconfigura antes de hacer cualquier cosa ofensiva
```

Un pentester que escanea accidentalmente su red doméstica o la infraestructura de su proveedor de internet queda, en el mejor de los casos, en una situación embarazosa, y en el peor, comete un delito. El aislamiento de la red es un hábito, no una sugerencia.

En Chile, la Ley 21.459 sobre delitos informáticos sanciona el acceso no autorizado a sistemas ajenos, y el hecho de que haya sido accidental no siempre protege. Consulta el texto vigente en BCN — LeyChile.

6.4 Verificación de herramientas

Las herramientas pueden estar desactualizadas o mal configuradas. Verifícalas antes de confiar en ellas:

```
# Versiones de las herramientas críticas:
nmap --version
msfconsole --version
sqlmap --version
nikto -Version
burpsuite --version 2>/dev/null || echo "Abre Burp desde el menú gráfico"

# Actualizar la base de scripts de Nmap:
sudo nmap --script-updatedb

# Actualizar Metasploit:
sudo msfupdate

# Actualizar la base de searchsploit:
sudo searchsploit -u

# Actualizar la base de locate (para búsquedas rápidas de archivos):
sudo updatedb
```

6.5 Configuraciones esenciales que suelen pasarse por alto

```
# Habilitar e iniciar PostgreSQL (requerido por Metasploit)
sudo systemctl enable postgresql --now
sudo msfdb init

# Configurar Git (para clonar herramientas y gestionar tus scripts):
git config --global user.name "Tu alias"
git config --global user.email "tu@correo.com"

# Editor predeterminado:
export EDITOR=vim  # o nano, o el que prefieras
echo 'export EDITOR=vim' >> ~/.zshrc

# Crear un espacio de trabajo estructurado:
mkdir -p ~/engagements ~/tools ~/wordlists ~/scripts

# Listas de palabras adicionales (más allá de las que trae Kali).
# SecLists es el estándar de referencia:
sudo apt install -y seclists
ls /usr/share/seclists/
```

> **Perspectiva:** SecLists (`/usr/share/seclists/`) es uno de los recursos más valiosos de tu máquina. Contiene listas de palabras para nombres de usuario, contraseñas, URL, cargas útiles, shells web y mucho más. Saber qué hay en SecLists y elegir la lista correcta para cada situación es una habilidad que distingue a los pentesters eficaces.

Referencia: SecLists en GitHub

7. Más allá de lo básico: configuración de vanguardia

7.1 Pila de herramientas moderna

Además de las herramientas predeterminadas de Kali, puedes instalar estas adiciones modernas que muchos cursos ignoran:

```
# Suite de ProjectDiscovery: herramientas de reconocimiento modernas y rápidas,
escritas en Go
go install -v github.com/projectdiscovery/nuclei/v3/cmd/nuclei@latest
go install -v github.com/projectdiscovery/httpx/cmd/httpx@latest
go install -v github.com/projectdiscovery/subfinder/v2/cmd/subfinder@latest
go install -v github.com/projectdiscovery/katana/cmd/katana@latest

# Asegurar que el directorio bin de Go esté en el PATH:
```

```
        echo 'export PATH=$PATH:$(go env GOPATH)/bin' >> ~/.zshrc

        # Rustscan: escaneo de puertos más rápido (escrito en Rust)
        # Escanea los 65535 puertos en segundos y pasa los abiertos a Nmap
        sudo apt install -y rustscan

        # Feroxbuster: descubrimiento de contenido rápido (basado en Rust)
        sudo apt install -y feroxbuster

        # Caido: proxy moderno para pruebas web (alternativa a Burp)
        # Descargar desde caido.io: es un binario independiente
```

7.2 Entornos de Python: buenas prácticas

Muchas herramientas de Kali dependen de versiones específicas de Python. Protégete con entornos virtuales:

```
        # Nunca uses pip install --break-system-packages a nivel global (Kali 2026 lo
bloquea por defecto)
        # En su lugar, usa entornos virtuales:

        # Crear un entorno para herramientas de pentest:
        python3 -m venv ~/venvs/pentest
        source ~/venvs/pentest/bin/activate

        # Instalar herramientas de Python de forma segura:
        pip install pwntools impacket

        # Desactivar cuando termines:
        deactivate

        # Para herramientas de uso puntual, pipx las instala en entornos aislados:
        sudo apt install -y pipx
        pipx ensurepath
        pipx install impacket
        pipx install certipy-ad
```

> **Nota:** `crackmapexec` está descontinuado y su desarrollo pasó a NetExec (`nxc`). Para trabajo nuevo, instala NetExec.

7.3 tmux: multiplexor de terminal persistente

tmux permite ejecutar varias sesiones de terminal que sobreviven aunque se caiga tu conexión SSH:

```
        # Iniciar una nueva sesión de tmux
        tmux new -s pentest

        # Atajos (Ctrl+B es el prefijo):
```

```
        # Ctrl+B, c      → nueva ventana
        # Ctrl+B, n/p    → ventana siguiente / anterior
        # Ctrl+B, %      → dividir el panel verticalmente
        # Ctrl+B, "      → dividir el panel horizontalmente
        # Ctrl+B, d      → desconectar (la sesión sigue activa)
        # tmux attach -t pentest  → reconectarse después

        # Por qué importa en los compromisos:
        # Ventana 0: escaneo de Nmap en curso
        # Ventana 1: pruebas web en Burp
        # Ventana 2: notas y documentación
        # Ventana 3: listener para reverse shell
        # Todas persistentes, todas accesibles, todas sobreviven a las desconexiones
```

Referencia: wiki de tmux

8. Entender la estructura del menú de Kali

Kali organiza las herramientas en su menú de aplicaciones por fase de ataque. Entender esta estructura te ayuda a descubrir herramientas:

```
01 - Information Gathering
  ├── DNS Analysis (dnsenum, dnsrecon, fierce)
  ├── IDS/IPS Identification (wafw00f)
  ├── Live Host Identification (arping, fping, netdiscover)
  ├── Network & Port Scanners (nmap, masscan, unicornscan)
  ├── OSINT Analysis (maltego, spiderfoot, theHarvester)
  ├── Route Analysis (netmask, traceroute)
  ├── SMB Analysis (enum4linux, smbmap)
  └── SNMP Analysis (onesixtyone, snmpwalk)

02 - Vulnerability Analysis
  ├── Fuzzing Tools (spike, sfuzz)
  └── VoIP Tools (sipvicious)

03 - Web Application Analysis
  ├── CMS & Framework Identification (wpscan, joomscan)
  ├── Web Application Proxies (burpsuite, zaproxy)
  ├── Web Crawlers & Directory Bruteforce (dirb, gobuster, feroxbuster)
  └── Web Vulnerability Scanners (nikto, wapiti, nuclei)

04 - Database Assessment (sqlmap)

05 - Password Attacks
  ├── Offline Attacks (hashcat, john)
  ├── Online Attacks (hydra, medusa, patator)
  └── Password Profiling & Wordlists (cewl, crunch, cupp)

06 - Wireless Attacks (aircrack-ng suite, wifite, bully)

07 - Reverse Engineering (ghidra, radare2, rizin)

08 - Exploitation Tools (metasploit, searchsploit)
```

```
09 - Sniffing & Spoofing (bettercap, ettercap, responder, wireshark)

10 - Post Exploitation
  ├── OS Backdoors (weevely)
  └── Tunneling & Exfiltration (chisel, ligolo-ng, proxychains)

11 - Forensics (autopsy, binwalk, volatility)

12 - Reporting Tools (cutycapt, faraday, pipal)

13 - Social Engineering Tools (set)
```

Esto no es solo un menú, es una metodología. La numeración sigue el ciclo de vida de la prueba de penetración: recopilar información → encontrar vulnerabilidades → explotar → post-explotación → informe.

9. Recomendaciones de hardware

9.1 Especificaciones mínimas y recomendadas

Componente	Mínimo	Recomendado	Notas
CPU	2 núcleos	4 o más núcleos	El cracking de hashes y el escaneo en paralelo necesitan núcleos
RAM	4 GB (para VM)	8 a 16 GB (para VM)	Burp, el navegador y las herramientas consumen 4 GB con facilidad
Disco	40 GB	80 a 120 GB	Listas de palabras, capturas y herramientas crecen rápido
Red	Integrada	Adaptador WiFi USB	Las tarjetas internas rara vez soportan modo monitor
GPU	Integrada	NVIDIA dedicada	Opcional: cracking acelerado por GPU con hashcat

9.2 Adaptadores USB WiFi recomendados

Para pruebas inalámbricas, tu tarjeta WiFi interna casi seguro no soporta modo monitor ni inyección de paquetes. Necesitas un adaptador externo con el chipset adecuado:

- **Alfa AWUS036ACH**: doble banda, CA, chipset Realtek RTL8812AU, buena gama.
- **Alfa AWUS036ACSM**: USB 3.0, antena dual, inyección confiable.
- **TP-Link TL-WN722N v1**: opción económica, chipset Atheros AR9271 (solo la versión 1; las versiones posteriores cambiaron de chipset).

> **Perspectiva:** el chipset importa más que la marca. Busca adaptadores con chipsets Atheros AR9271, Ralink RT3070 o Realtek RTL8812AU, que tienen soporte maduro en Linux con capacidad de inyección. No compres adaptadores solo por la compatibilidad anunciada con Linux: verifica la revisión del chipset.

10. Ejercicio práctico: configuración de tu laboratorio

Objetivo

Configurar un laboratorio completo de pentest con una máquina virtual de ataque Kali 2026 y una máquina objetivo para lecciones posteriores.

Pasos

Paso 1: descarga e importa la imagen de Kali 2026.

```
# Descargar desde https://www.kali.org/get-kali/#kali-virtual-machines
# Elegir tu hipervisor (VMware o VirtualBox)
# Extraer e importar la imagen
```

Paso 2: configura la máquina virtual según la tabla de la sección 4.1.

Paso 3: arranca y haz la configuración inicial.

```
# Actualizar el sistema
sudo apt update && sudo apt full-upgrade -y

# Configurar la zona horaria
sudo timedatectl set-timezone <tu-zona-horaria>

# Generar la clave SSH
ssh-keygen -t ed25519 -C "student@pentest-lab"

# Instalar lo esencial
```

```
sudo apt install -y kali-tools-top10 seclists docker.io docker-compose-v2
sudo systemctl enable docker --now
sudo usermod -aG docker $USER

# Configurar la terminal
sudo apt install -y tmux
```

Paso 4: crea una instantánea llamada “Clean-Base-Setup”.

Paso 5: verifica la instalación de las herramientas.

```
# Ejecuta estos comandos y confirma que cada uno devuelve una versión:
nmap --version && echo "OK" || echo "FAIL"
msfconsole -v && echo "OK" || echo "FAIL"
sqlmap --version && echo "OK" || echo "FAIL"
python3 --version && echo "OK" || echo "FAIL"
docker --version && echo "OK" || echo "FAIL"
```

Paso 6: descarga tu primer entorno objetivo.

```
docker pull vulnerables/web-dvwa
docker run -d -p 127.0.0.1:80:80 vulnerables/web-dvwa
# Abre http://localhost en el navegador: deberías ver la pantalla de login de
DVWA
# Credenciales por defecto: admin / password
```

Referencia: DVWA en GitHub

Resultado esperado: una máquina virtual de Kali con acceso a internet, herramientas actualizadas, Docker configurado y DVWA corriendo como tu primera aplicación objetivo.

11. Ejercicio de reflexión

1. **¿Por qué Linux domina las herramientas de ciberseguridad?** Piensa más allá de “es gratis”. Considera las decisiones de arquitectura técnica que lo hacen adecuado para el trabajo de seguridad. ¿Cómo beneficia la filosofía Unix de herramientas componibles al flujo de trabajo diario de un pentester?
2. **Compara las ventajas y desventajas de ejecutar Kali como máquina virtual, en hardware dedicado o en WSL2.** ¿En qué escenarios de compromiso sería cada opción más adecuada? ¿Cuáles son las implicaciones de seguridad de cada elección?
3. **Te preparas para un compromiso de pruebas de penetración en una institución financiera.** El cliente exige cifrado completo de disco en todo el hardware del compromiso, entornos separados por trabajo y documentación lista para auditoría. Diseña tu configuración de Kali para cumplir estos requisitos. Considera: ¿cuántas

máquinas virtuales usarías? ¿Qué estrategia de instantáneas? ¿Cómo proteges los datos en reposo y en tránsito?

Resumen

Linux no es solo la plataforma de las pruebas de penetración: es la habilidad. Cada concepto que aprendas sobre Linux (archivos, procesos, permisos, redes) se traduce directamente en técnicas de enumeración, explotación y post-explotación que usarás en compromisos reales.

Ahora tienes un entorno Kali 2026 funcionando y configurado para aprender. En la siguiente lección exploramos la jerarquía del sistema de archivos de Linux: exactamente dónde vive cada cosa y por qué a un pentester le importa cada directorio.

Recursos adicionales

- Documentación de Kali Linux: guías oficiales de instalación y configuración.
- Descargas de Kali (máquinas virtuales): imágenes para VMware, VirtualBox, WSL y ARM.
- Catálogo de herramientas de Kali: meta-paquetes y herramientas por categoría.
- OffSec: la organización detrás de Kali y su biblioteca de capacitación.
- Linux From Scratch: construye tu propio sistema Linux desde el código fuente (aprendizaje profundo).
- The Linux Command Line, William Shotts: libro gratuito y referencia excelente.
- OverTheWire: Bandit: practica los fundamentos de Linux con desafíos.
- SecLists en GitHub: colección de listas de palabras.
- Documentación de Docker.
- Manual de VirtualBox.
- Nmap: libro oficial: referencia completa de Nmap.